

RAPPORT DE SÉCURITÉ ORTHRUS

API Penetration Testing Report

Cible:

<https://petstore3.swagger.io/api/v3/openapi.json>

Date du Scan: 2026-06-02 22:02:16

Avertissement Légal & Confidentialité

Ce rapport est STRICTEMENT CONFIDENTIEL et sa distribution est soumise à restriction. Il est destiné uniquement à un usage autorisé. Il est généré par un outil automatisé de test de sécurité (Orthrus). L'outil assigne un score CVSS de Base qui ne pas refléter le contexte environnemental ou temporel de la vulnérabilité. Les auteurs et l'outil lui-même déclinent toute responsabilité en cas de vulnérabilité non détectée, de failles critiques manquées, ou de compromissions ultérieures. Cet outil est fourni exclusivement pour des tests de sécurité autorisés et encadrés.

Méthodologie et Critères d'Évaluation

Ce rapport présente les résultats d'une analyse automatisée de sécurité dynamique (DAST). L'analyse a consisté à envoyer des payloads malveillants et des entrées inattendues à l'API cible afin d'identifier les vulnérabilités de sécurité.

Orthrus utilise une taxonomie avancée pour catégoriser ses découvertes.

- **Score CVSS 3.1 Base** : Fournit un score numérique théorique (0.0 à 10.0) reflétant les qualités intrinsèques de la vulnérabilité.
- **CAPEC** : Common Attack Pattern Enumeration and Classification, identifiant le mécanisme exact de l'attaque.
- **OWASP** : Lie chaque vulnérabilité au classement de sécurité API Top 10 le plus récent.
- **Note de Sécurité Globale** : Une note (de A à F) évaluant la posture globale de sécurité, basée sur la vulnérabilité la plus critique trouvée.

1. Résumé Global

Note de S

F

CRITIQUE	ÉLEVÉ	MOYEN	FAIBLE	INFO	VUI
3	2	20	95	0	

2. Résumé des Vulnérabilités

Sévérité	Détails des Vulnérabilités	Point de Terminaison
CRITIQUE	Missing Authentication for Critical Function	https://petstore3.swagger.io/api/v3/pet/{petId}
CRITIQUE	Missing Authentication for Critical Function	https://petstore3.swagger.io/api/v3/store/owners/{ownerId}/pets/{petId}
CRITIQUE	Missing Authentication for Critical Function	https://petstore3.swagger.io/api/v3/store/owners/{ownerId}/pets/{petId}/uploadImage
ÉLEVÉ	Potential Broken Function Level Authorization	https://petstore3.swagger.io/api/v3/pet/{petId}
ÉLEVÉ	Potential Broken Function Level Authorization	https://petstore3.swagger.io/api/v3/store/owners/{ownerId}/pets/{petId}

3. Résultats Détaillés

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base:

9.8

CWE: CWE_306

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Request:

Sent DELETE request without Authorization header.

Response:

Status: 200 OK

Body snippet: Pet deleted

Remédiation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base:

9.8

CWE: CWE_306

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Request:

Sent POST request without Authorization header.

Response:

Status: 200 OK

Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remédiation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Sévérité:

CRITIQUE

Score CVSS de Base:

9.8

CWE: CWE_306

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint exposes sensitive operations without requiring authentication.

Preuve

Endpoint returned 200 OK OK without any authentication credentials

Request:

Sent DELETE request without Authorization header.

Response:

Status: 200 OK
Body snippet:

Remédiation

Implement robust authentication for this endpoint.

Potential Broken Function Level Authorization

Sévérité:

ÉLEVÉ

Score CVSS de Base:

9.8

CWE: CWE_285

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. The current user should have this privilege.

Preuve

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Request:

Sent DELETE request to <https://petstore3.swagger.io/api/v3/pet/49>

Response:

Status: 200 OK

Remédiation

Ensure function-level access control checks exist for all administrative operations and methods.

Potential Broken Function Level Authorization

Sévérité:

ÉLEVÉ

Score CVSS de Base:

9.8

CWE: CWE_285

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. The current user should have this privilege.

Preuve

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Request:

Sent DELETE request to <https://petstore3.swagger.io/api/v3/store/order/5>

Response:

Status: 200 OK

Remédiation

Ensure function-level access control checks exist for all administrative operations and methods.

Sensitive Information in Query String

Sévérité:

MOYEN

Score CVSS de Base:

6.5

CWE: CWE_598

Référence CAPEC: CAPEC-87

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint accepts a parameter named 'password' in the URL query string. Query strings are logged by reverse servers, and browser histories, leading to sensitive data exposure.

Preuve

Parameter 'password' found in GET request.

Request:

URL requested: <https://petstore3.swagger.io/api/v3/user/login> with parameter password

Response:

Status: Static Analysis (No request sent)

Body snippet: Not applicable. This vulnerability is detected statically from the API schema/specification

Remédiation

Move sensitive data from the query string to HTTP Headers (e.g., Authorization header) or the request body (e.g.,

Reflected Cross-Site Scripting (XSS)

Sévérité:

MOYEN

Score CVSS de Base:

6.1

CWE: CWE_79

Référence CAPEC: CAPEC-63

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Preuve

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute in browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

Injected XSS payload into query param: status=<script>alert('XSS_VULNAPI_TEST')</script>

Response:

```
Status: 400 BAD_REQUEST
Content-Type: application/json
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `
```

Remédiation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base:

6.5

CWE: CWE_352

Référence CAPEC: CAPEC-62

Point de Terminaison: `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit `Origin` in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with `Origin: https://malicious-website.com` and no CSRF tokens.

Request:

```
Sent DELETE request stripped of CSRF headers and injected Origin: https://malicious-website.com.
```

Response:

```
Status: 200 OK  
Body snippet: Pet deleted
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the `SameSite=Lax` or `Strict` attribute.

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base:

7.5

CWE: CWE_639

Référence CAPEC: CAPEC-17

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 37 to 38. Ensure the auther has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 38

Request:

Modified URL from <https://petstore3.swagger.io/api/v3/pet/37> to <https://petstore3.swagger.io/api/v3/pet/38>

Response:

Status: 200 OK

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access

Potential Broken Object Level Authorization (BOLA)

Sévérité:

MOYEN

Score CVSS de Base:

7.5

CWE: CWE_639

Référence CAPEC: CAPEC-17

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 37 to 36. Ensure the auther has permission to access this specific object.

Preuve

Response status 200 OK when accessing ID 36

Request:

Modified URL from <https://petstore3.swagger.io/api/v3/pet/37> to <https://petstore3.swagger.io/api/v3/pet/36>

Response:

Status: 200 OK

Remédiation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to a

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base:

6.5

CWE: CWE_352

Référence CAPEC: CAPEC-62

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit `Origin` in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Request:

Sent POST request stripped of CSRF headers and injected Origin: <https://malicious-website.com>.

Response:

Status: 200 OK

Body snippet: `{"id":0,"petId":0,"quantity":0,"complete":false}`

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the `SameSite=Lax` or `Strict` attribute.

Potential Mass Assignment (BOPLA)

Sévérité:

MOYEN

Score CVSS de Base:

6.5

CWE: CWE_915

Référence CAPEC: CAPEC-17

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint accepts unexpected fields (e.g., 'is_admin', 'role') in the JSON payload without returning a validation

Preuve

Server returned 200 OK OK after injecting privilege escalation fields into the JSON payload.

Request:

```
Injected fields into JSON body: {"data":"iste","is_admin":true,"isAdmin":true,"role":"admin","permission":true}
```

Response:

Status: 200 OK

Remédiation

Use DTOs (Data Transfer Objects) to explicitly map accepted fields. Avoid binding HTTP requests directly to domain database entities.

Potential Cross-Site Request Forgery (CSRF)

Sévérité:

MOYEN

Score CVSS de Base:

6.5

CWE: CWE_352

Référence CAPEC: CAPEC-62

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit `Origin` in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Preuve

Server accepted the request with `Origin: https://malicious-website.com` and no CSRF tokens.

Request:

```
Sent DELETE request stripped of CSRF headers and injected Origin: https://malicious-website.com.
```

Response:

```
Status: 200 OK  
Body snippet:
```

Remédiation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the `SameSite=Lax` or `Strict` attribute.

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b888ad10b94ff840)"}

```

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d4dd66e4284c8a85)"}
```

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 404 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 404 NOT_FOUND
Body snippet: Pet not found

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK
Body snippet: Pet deleted

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 400 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 400 BAD_REQUEST
Body snippet: No file uploaded

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK

Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Request:

```
Sent 30 identical requests in rapid succession.
```

Response:

```
Status: 200 OK  
Body snippet:
```

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 06da53704e55ae86)"}

```

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 400 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 400 BAD_REQUEST

Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User"}

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK
Body snippet: Logged in user session: 4130310727093313104

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 97324972bb61d05d)"}

```

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Sévérité:

MOYEN

Score CVSS de Base:

5.3

CWE: CWE_799

Référence CAPEC: CAPEC-115

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Preuve

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b0dd7d63683b96d1)"}
b0dd7d63683b96d1")}

Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:18 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:fa5935f0af424286)"}

```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:18 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:fa5935f0af424286)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:18 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:fa5935f0af424286)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:18 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:fa5935f0af424286)"}

```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: fa5935f0af424286)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:055f370c815c9858)"}

```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:055f370c815c9858)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:055f370c815c9858)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:055f370c815c9858)"}

```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 055f370c815c9858)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `ea` is not in the allowed values [available, pending, sold]`"}
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `ea` is not in the allowed values [available, pending, sold]`"}
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `ea` is not in the allowed values [available, pending, sold]`"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `ea` is not in the allowed values [available, pending, sold]`"}
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `ea` is not in the allowed values [available, pending, sold]`"}
```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:1024, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:1000, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: []

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type",
Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length: Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet not found

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type",
Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet not found

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, api_key, Authorization", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet deleted

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: No file uploaded

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: No file uploaded
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: No file uploaded
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:19 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: No file uploaded
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: No file uploaded

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:20 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:8d2e6d80dc2bbb03)"}

```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:20 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8d2e6d80dc2bbb03)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:20 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8d2e6d80dc2bbb03)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 20:02:20 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8d2e6d80dc2bbb03)"}
8d2e6d80dc2bbb03)"}
}

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8d2e6d80dc2bbb03)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type",
Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 20:02:21 GMT", Content-Type:"application/xml", Content-Length:
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type",
Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Order not found

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v2023-09-14)"]
Body snippet:

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v2023-09-14)"]
Body snippet:

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Length:"0", Connection:"keep-alive", Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"(api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v2023-09-14)"]

Body snippet:

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v2023-09-14)"]
Body snippet:

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet:

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User"}
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User"}
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User"}
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User"}
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.l

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100,
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type,
Content-Length, Content-Range, ETag, Last-Modified, Location, Range, Server, Vary", Server:"Jetty(9.4.53.v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d15a381f1bea2194)"} }
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d15a381f1bea2194)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Location", Server:"Jetty(9.4.53.v20231009)"]

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d15a381f1bea2194)"}
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```

Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100,
Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE",
Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type,
Content-Length, Content-Range, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d15a381f1bea2194)"} }
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d15a381f1bea2194)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, X-Rate-Limit", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 21:02:29 UTC 2026", Server:"Jetty(9.4.53.v20230620)"]
Body snippet: Logged in user session: 3257646420549715977

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 21:02:29 UTC 2026", Server:"Jetty(9.4.53.0)"]
Body snippet: Logged in user session: 3257646420549715977
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 21:02:29 UTC 2026", Server:"Jetty(9.4.53.0)"]
Body snippet: Logged in user session: 3257646420549715977
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:1024, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, X-Rate-Limit", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 21:02:29 UTC 2026", Server:"Jetty(9.4.53.v20230620)"]
Body snippet: Logged in user session: 3257646420549715977

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/login>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: Logged in user session: 3257646420549715977

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Type, Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 20:02:29 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/logout>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: User logged out

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:33e61f5e974df7f3)"}

```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:33e61f5e974df7f3)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:33e61f5e974df7f3)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:33e61f5e974df7f3)"}

```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 33e61f5e974df7f3)"}
```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```

Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: e9b4d110825cd5a4)"}
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: e9b4d110825cd5a4)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: e9b4d110825cd5a4)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: e9b4d110825cd5a4)"}

```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: e9b4d110825cd5a4)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 9c2b1b6775992146)"}

```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:9c2b1b6775992146)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_1021

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID:9c2b1b6775992146)"}

```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base:

4.3

CWE: CWE_693

Référence CAPEC: CAPEC-310

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 20:02:30 GMT", Content-Type:"application/json", Content-Length:100, Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 9c2b1b6775992146)"}

```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all response

Information Exposure: Server Header

Sévérité:

FAIBLE

Score CVSS de Base:

3.7

CWE: CWE_200

Référence CAPEC: CAPEC-118

Point de Terminaison: <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Preuve

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 9c2b1b6775992146)"}

```

Remédiation

Configure your web server to remove or mask the 'Server' header.